

Part 1 – Security Principles & Threat Modeling

The CIA Triad:

A core cybersecurity model that stands for confidentiality, Integrity, and availability.

Confidentiality: Prevents unauthorized access to sensitive data through;
(Encryption, access control)

Integrity: Ensures data remains accurate and unaltered through; (Hashing, data signature)

Availability: Ensures data is accessible anywhere whenever the data is needed;
(backups and redundancy.)

Threat Vectors & Social Engineering:

A threat vector is the path or technique used by a cyberattacker to gain unauthorized access to a system (the “door” or “tunnel”).

Types of threat vector types:

- Social Engineering (exploiting human psychology)
- Software Vulnerability (taking advantage of a code flaw)
- Credential compromise (stealing valid authentication data)
- Malware (malicious software that compromises a system)

Social Engineering:

This process involves the cyberattacker exploiting human psychology through manipulation and impersonation.

It is achieved by:

- Authority (Impersonating as a person of high rank to make orders)
- Fear/Urgency (making employees make bias decisions like wire transfers)
- Intimidation (making threats if certain actions are not met)

Methods include:

- Phishing (sending malicious emails to customers, employees)
- Smishing (sending SMS messages)
- Pharming (redirection to malicious web pages)
- Typo squatting (omitting/adding letters to URLs)
- Vishing (using voice for manipulation)

Other threat vectors that make cyberattackers have access to systems is through:

- Weak encryption (employing stronger encryption methods like AES)
- Obsolete data, devices, or applications (When not appropriately uninstalled, deleted, or discarded, obsolete endpoints, applications, and user accounts can create security weaknesses that cybercriminals can easily exploit)

How to mitigate risk from threat vectors:

Network segmentation (dividing networks to avoid lateral movement)

Strong encryption (adopting strong encryption methods)

Threat intelligence (having detected threats to anticipate for future threats)

Vulnerability scanning/assessment (testing systems to check flaws)

Regular updates (having the latest software)

MITRE ATT&CK Framework

The MITRE ATT&CK framework is a universally accessible, continuously updated knowledge base for modeling, detecting, preventing and fighting cybersecurity threats based on cybercriminals' known adversarial behaviors.

ATT&CK stands for adversarial tactics techniques and common knowledge.

The tactic explains the “what” the method that cyberattacker uses to attack a system e.g. privilege escalation.

The technique explains the “how” how the privilege escalation was made.

When cybersecurity professionals detect the threat, the MITRE ATT&CK framework is used to understand and map how the attack was being carried out and to check the mitigation methods against the attack.

The MITRE ATT&CK framework is categorized into matrices that is used to visualize the tactics (the adversary's technical goal e.g initial Access) and Techniques (the action taken to achieve that goal, e.g Phishing or Pass-the-Hash).

Part 2 – Real-World Breach Case Study

The 2022 Uber Cyberattack

1. Background

On September 15, 2022, one of the world's top rides hailing companies suffered a security breach by an 18-year-old hacker who was affiliated with **Lapsus\$ group** which had successful attacks against tech giants like Microsoft, Nvidia and Samsung.

The attacker gained access to Uber's internal infrastructure, compromise of internal communication channels (Slack), administrative portals, Google Workspace, and cloud environments (AWS).

2. Attack Vector & Initial Access

Compromising Credentials: the hacker used the username and password of an uber employee that had purchased off the dark web obtained from a previous data breach.

MFA Fatigue Attack: a psychological rather than technical tactic, the attacker continuously sends MFA approval requests to the target user. The user initially rejects these requests, but the attacker does not give up and continues sending these requests for hours. Eventually, either to get rid of the annoyance or thinking it was a legitimate IT request, the user approved one of these prompts. This single click was enough for the attacker to gain access to Uber's VPN network.

WhatsApp Social Engineering: IT Support Impersonation: They **contacted the targeted employee via WhatsApp**, introducing themselves as someone from Uber's IT department. They told them that the continuous MFA notifications were a security test and that the employee needed to approve these tests. This tactic was a classic example of using an "authority figure" and unfortunately, it worked.

Internal Propagation: Privilege Escalation and Lateral Movement

The attacker began lateral movement within Uber's internal network, they found hardcoded administrator credentials within **PowerShell scripts**. This was one of the most basic mistakes that could be made in corporate security and handed the attacker a golden opportunity for privilege escalation.

IMPACT ON THE CIA TRIAD.

Full Access to Critical Systems.

With these administrator credentials, the attacker infiltrated Uber's most critical systems:

Amazon Web Services (AWS) - The heart of the company's cloud infrastructure

Google Cloud Platform (GCP) - Data storage and processing systems

Slack - Internal communication platform and sensitive corporate information.

HackerOne - Ironically, the platform where security vulnerabilities are reported.

Internal code repositories - Access to Uber's source code

Databases - Systems containing customer and company data.

Confidentiality (High Impact): Critical internal documentation, source code repositories, vulnerability reports on HackerOne, and internal communications on Slack were exposed to the attacker.

Integrity (Medium Impact): The attacker altered internal network configurations (displaying explicit images on intranet sites) and posted unauthorized messages on public employee Slack channels.

Availability (Low/Medium Impact): Uber was forced to temporarily take internal communication tools, software management systems, and codebase repositories offline to contain the incident.

Remediation and Key Lessons learned.

The immediate incident response that Uber did was:

Blocked accounts: Disabled compromised contractor/employee credentials.

Forced resets: Required mandatory password resets.

Disabled tools: Cut off affected internal tooling and Slack/Telegram integrations.

Rotated keys: Regenerated internal server access keys, AWS, and Google Workspace secrets.

Locked codebase: Restricted repository access and re-authenticated developer sessions

Technical Safeguards

Implement **number matching** (user types a number shown on-screen).

Enforce **rate limiting / push-bombing defense** (lock/delay after failed spam attempts).

Deploy **phishing-resistant FIDO2 hardware security keys** (WebAuthn)

Secret Management:

- Eliminate **hardcoded plain-text credentials** in PowerShell/shared scripts.
- Adopt a centralized **Privileged Access Management (PAM)** vault with dynamic short-lived tokens.

Zero Trust Architecture:

- Enforce continuous verification (device health, identity, anomalous location/behavior) post-login.
- Segment internal corporate VPN and privileged admin networks.

Organizational & Human Defenses

- **Social engineering drills:** Train staff and third-party contractors to spot out-of-band WhatsApp/SMS IT impersonation.
- **Clear escalation paths:** Establish instant reporting channels for MFA fatigue or suspicious prompts.

- **Vendor/Contractor oversight:** Audit third-party endpoint compliance and least privilege access rules.

Policy & Governance Frameworks

- **Compliance alignment:** Align with **NIST CSF** or conduct annual **ISO/IEC 27001** audits.
- **Two-person rule:** Require multi-person approval for high-privilege infrastructure modifications

Part 3 Practical Security Awareness Recommendations

Phishing & Social Engineering: Address that ~99% of malicious modern emails rely on manipulation/deceptive links rather than raw malware payloads. Teach pausing and verifying.

Outbound Call Verification: Never ask callers for PII first; use secondary push/text confirmation loops (mirroring modern banking standards).

Credential Hygiene: Multi-factor authentication (MFA) awareness, spotting fake login/LinkedIn profiles, and avoiding reuse.

Remote & Hybrid Endpoints: Enforce VPN usage on public Wi-Fi, home router security, OS updates, and BYOD separation.

Ransomware Response: Immediate network disconnection steps for affected hardware.

Physical & Social Media Awareness: Avoid workplace background/badge/desk selfies leaking data; enforce shredding and clean-desk habits.